

Contents

Page

1.

Liability Disclaimer

1

2.

Executive summary.....

1

3.

Scope

2

5.

Methodology.....

3

6.

Finding and Proof of Exploitation.....

3

7.

Risk Rating.....

13

8.

Recommendations and Remediation

14

9.

Conclusion

15

PENETRATION TESTING REPORT

W4-PM-FINAL | CYBERSECURITY | NETWORKWALKS

1. Liability Disclaimer

I have performed these activities only on systems and devices for which I had secured written authorization.

This project is conducted in a controlled environment for educational purposes only. The target has been authorised for security testing by Networkwalks. These techniques must never be applied to any system without explicit written permission from the owner.

All materials are provided strictly for **educational and research purposes**. Do not use any information, techniques, tools, or examples presented here to violate laws, access systems without permission, or cause harm.

The instructor, authors, and Networkwalks are not responsible for how this knowledge is used. Every action you take is your own responsibility. Misuse of these materials may result in criminal prosecution, significant fines, loss of employment, civil liability, and a permanent criminal record.

In many countries, unauthorized access to a computer system, network, application, or device is a criminal offense—even if no data is altered, stolen, or damaged.

2. Executive summary

During the scheduled security assessment, a Critical-severity SQL Injection (SQLi) vulnerability was discovered on the primary application login gateway. Throughout testing, the username parameter accepted the input " `admin'--` ", which resulted in successful authentication without supplying the legitimate account password. This completely bypasses the authentication mechanism, granting access to the application for non-authorized user without a valid password. This behaviour indicates that user-controlled input may be incorporated into an SQL query without adequate parameterization, potentially allowing an attacker to bypass authentication and gain unauthorized access. This flaw poses an immediate threat to data confidentiality, system integrity, and overall regulatory compliance.

3.Scope

Pentester Name (Cybersecurity Professional)	Bikila Giragn Garba
Program/Batch	B083-Networkwalks
Date	29 Sep 2026
Project Type	Penetration Testing & Vulnerability Assessment
Client Name	Client Name Mediroza General Hospital
Target Domain	https://medirozahospital.com
Scope	Full black-box penetration test. Identify vulnerabilities, exploit them to demonstrate real impact, and document all findings in a professional report
Rules	Testing limited to the target domain only. No social engineering. No denial of service. No testing outside agreed scope.
Authorization	The client has provided written authorisation to conduct security testing on their web infrastructure.
Timeline	5 days. Work independently. Do not discuss findings with other participants until the reveal session.

5. Methodology

The assessment included controlled testing of the application's authentication mechanism for input-validation and SQL injection weaknesses. The username parameter was tested with specially crafted input while an invalid or blank password was supplied.

Test Input

Username: admin'--

Password: [Invalid / Blank]

Tools:

- ✓ Web browser
- ✓ <https://networkwalks.com/hash-calculator/>
- ✓ <https://networkwalks.com/password-cracker/>

Limitation: Testing should remain within the authorized scope and should not include unauthorized accounts, systems, data modification, or destructive actions.

6. Finding and Proof of Exploitation

Finding: SQL Injection Authentication Bypass

The application's login functionality appears vulnerable to SQL injection through the username parameter. During testing, submitting " **admin'--** " as the username resulted in successful authentication without providing the legitimate password.

The payload contains SQL syntax that may terminate the application's username expression and cause the remainder of the SQL statement to be interpreted as a comment. The observed successful authentication indicates that the backend may be constructing SQL queries using unsafely handled user input.

Proof of Exploitation

Step 1 – Normal Login

Submit a legitimate or invalid username and password. Expected result: Authentication failed.

Message Displayed

Patient Portal

Sign in to view your lab reports and results.

Username not found

Username

username

Password

password

☒ Show password

Sign in

Step 2 – SQL Injection Test

Submit Username: admin'-- and Password: [invalid password]. Observed result: Authentication successful.

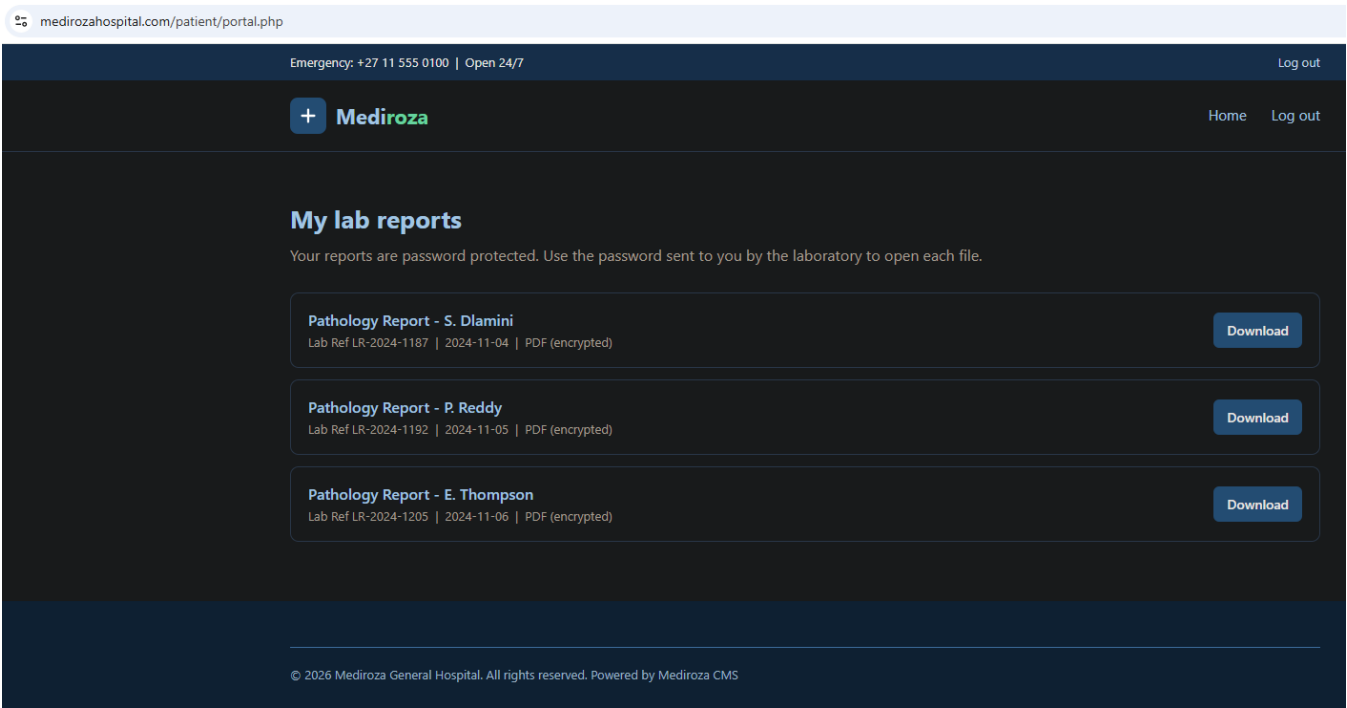
The screenshot shows the Mediroza Patient Portal login page. The browser address bar displays `medirozahospital.com/patient/login.php`. The page header includes the Mediroza logo, navigation links (Home, About, Doctors, Contact, Patient Portal), and emergency contact information (+27 11 555 0100 | Open 24/7). The main content area features a "Patient Portal" login form with the following elements:

- Username:** `admin'--` (highlighted with a red box)
- Password:** `password` (highlighted with a red box)
- ☒ Show password
- Sign in** button

The footer contains the copyright notice: © 2026 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS.

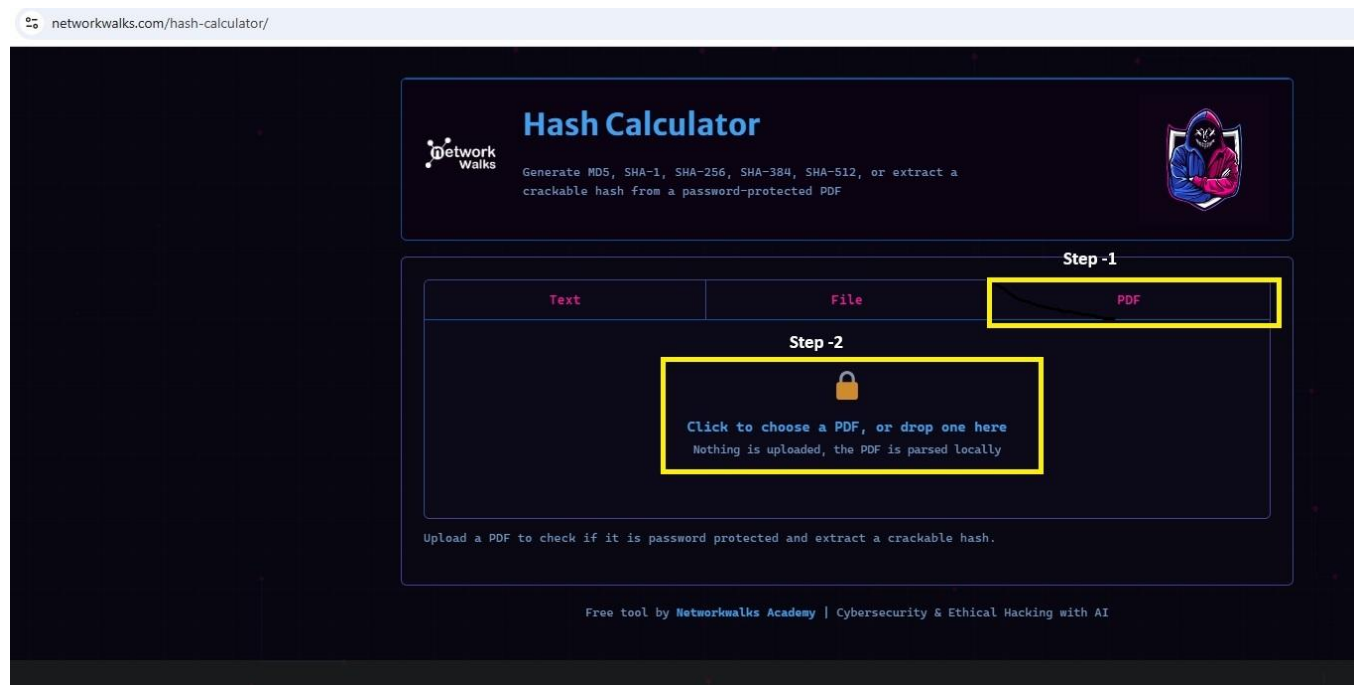
Step 3 – Verify Authentication

Confirm that an authenticated session was established and document the account and privileges presented by the application

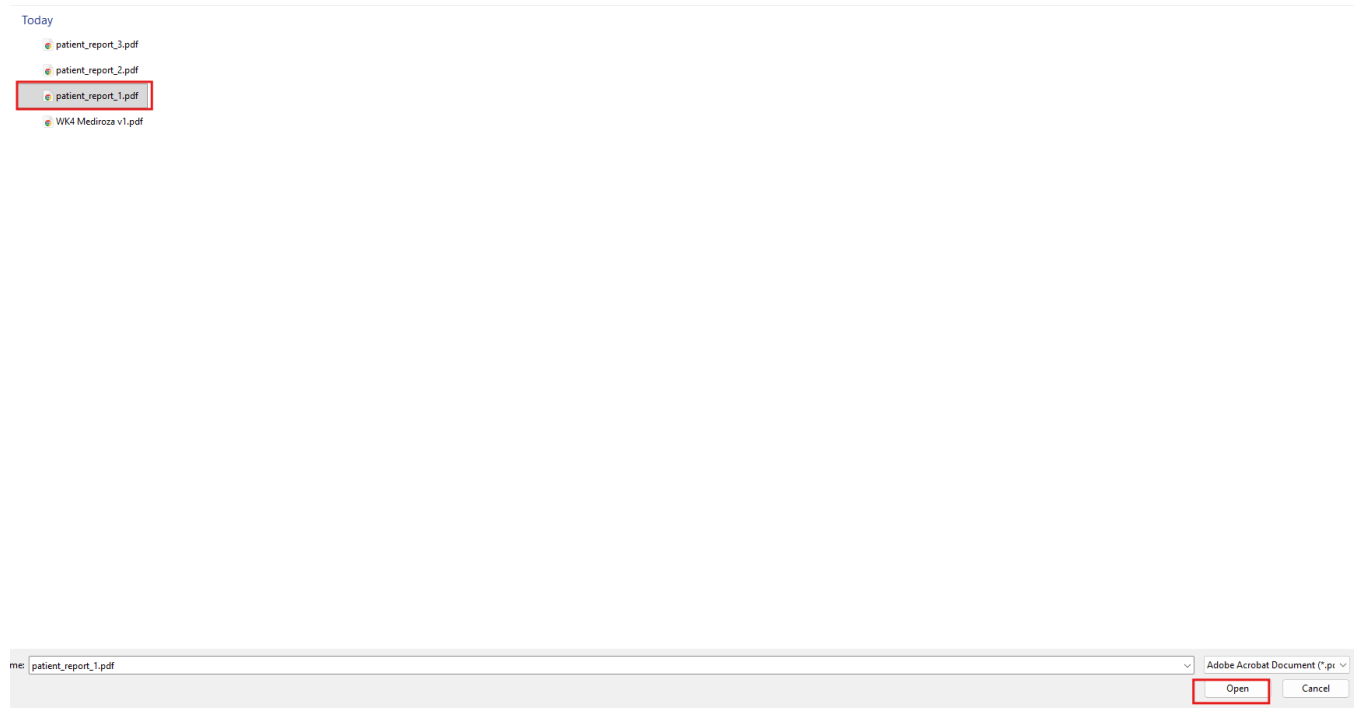


Step 4 - Download the three files and crack the password

Go to <https://networkwalks.com/hash-calculator/> and change the pdf files to hash.



Browse the pdf file



Copy the Hash File to <https://networkwalks.com/password-cracker/> and click start cracking

networkwalks.com/hash-calculator/

Hash Calculator

Generate MD5, SHA-1, SHA-256, SHA-384, SHA-512, or extract a crackable hash from a password-protected PDF

Text File PDF

Click to choose a PDF, or drop one here
Nothing is uploaded, the PDF is parsed locally

patient_report_1.pdf | 3.6 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

PDF Hash

```
$pdf$2*3*128*4294967292*1*32*3361663365326235643333353531613238303137316238333238373763333339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56ffffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6
```

Copy Download

Revision: R3 Version: V2 Key length: 128 bit

Upload a PDF to check if it is password protected and extract a crackable hash.

Free tool by Networkwalks Academy | Cybersecurity & Ethical Hacking with AI

networkwalks.com/password-cracker/

Password Cracker through Dictionary Attacks

Hash every word in a wordlist and match it against a PDF password hash, the same idea John the Ripper uses.

- 1 Extract the \$pdf\$ hash in the Hash Calculator
- 2 Paste it below
- 3 Run the attack, then open your PDF with the password

PDF HASH (\$PDF\$...)

```
$pdf$2*3*128*4294967292*1*32*3361663365326235643333353531613238303137316238333238373763333339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56ffffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6
```

Built-in list (100 passwords) Upload wordlist (.txt) Active: built-in list, 100 words

START CRACKING

Free tool by Networkwalks Academy | Cybersecurity & Ethical Hacking with AI

The password was successfully cracked

networkwalks.com/password-cracker/

Network Walks

Dictionary Attack Lab

Password Cracker through Dictionary Attacks

Hash every word in a wordlist and match it against a PDF password hash, the same idea John the Ripper uses.

- 1 Extract the \$pdf\$ hash in the [Hash Calculator](#)
- 2 Paste it below
- 3 Run the attack, then open your PDF with the password

Tried: 1 / 100 1000 pw/s 1%

```
[*] Loaded wordlist: built-in list (100 entries)
[*] Target: PDF R3 / 128-bit / dictionary attack
[*] Deriving keys with MD5 + RC4 ...
[+] MATCH 123456 ✓
```

PASSWORD CRACKED SUCCESSFULLY

123456

This is the PDF password. Open your PDF and enter it to unlock the file.

Copy password

PDF HASH (\$PDF\$...)

```
$pdf$2*3*128*4294967292*1*32*3361663365326235643333353531613238303137316238333238373763353339*32*ef16c52ab
8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56fffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102d
a468e77127f1e69d6
```



14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:	Sipho Dlamini	Report Date:	2024-11-04
Patient ID:	MG-P-10231	Referring Dr:	Dr. Anita Naicker
Date of Birth:	1984-06-12	Specimen:	Whole blood (EDTA)
Gender:	Male	Lab Ref No:	LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2

Do the same step for both files **patient_report_2.pdf** and **patient_report_3.pdf**

Finally, the password for patient_report_2.pdf is “password” and for patient_report_3.pdf is “!@#\$\$%^&”.

After opening the file name as “patient_report_2.pdf” looks like

**Mediroza**
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT**CONFIDENTIAL**

Patient Name:**Priya Reddy**

Report Date:**2024-11-05**

Patient ID:**MG-P-10244**

Referring Dr:**Dr. Johan van der Merwe**

Date of Birth:**1991-02-28**

Specimen:**Serum**

Gender:**Female**

Lab Ref No:**LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Susan Botha, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

While opened, the file name “ patient_report_3.pdf “ looks like



Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:**Emily Thompson**

Patient ID:**MG-P-10258**

Date of Birth:**1978-09-03**

Gender:**Female**

Report Date:**2024-11-06**

Referring Dr:**Dr. Ahmed Kara**

Specimen:**Serum**

Lab Ref No:**LR-2024-1205**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

7. Risk Rating

Severity: HIGH

Justification: The vulnerability potentially allows an unauthenticated user to bypass the application's authentication mechanism without knowing the legitimate password.

Potential impacts include:

- ✓ Unauthorized account access.
- ✓ Access to information available to the compromised account.
- ✓ Circumvention of password-based authentication.
- ✓ Potential privilege escalation if a privileged account can be targeted.

Unauthorized Access to Patient Health Information (PHI)

Risk Description: A vulnerability exists where password-protected patient files within the hospital network can be accessed without proper authorization. An incident involving the bypassing of file encryption or password controls demonstrates that current access controls are insufficient to protect Protected Health Information (PHI).

Regulatory Impact: This failure constitutes a direct breach of the *Health Insurance Portability and Accountability Act (HIPAA)* Security Rule, specifically regarding technical safeguards and access controls.

Potential Consequences:

- ✓ Severe financial penalties and legal sanctions from regulatory bodies for failing to maintain HIPAA compliance.
- ✓ Compromise of patient data privacy, leading to loss of trust and potential reputational damage to the institution.
- ✓ Increased vulnerability to further cyber threats due to unaddressed security gaps.

Recommended Actions: Immediate review and strengthening of encryption standards, implementation of multi-factor authentication (MFA) for all clinical files, and comprehensive auditing of access logs to detect and prevent unauthorized entry

8. Recommendations and Remediation

1. Use Parameterized Queries

- ✓ Implement prepared statements or parameterized queries for all database operations.
- ✓ Do not concatenate user-supplied values directly into SQL statements.

2. Implement Server-Side Input Validation

- ✓ Validate username input according to the application's legitimate requirements.
- ✓ Input validation should supplement, not replace, parameterized queries.

3. Review Authentication Logic

- ✓ Ensure password verification is always performed, malformed input cannot bypass authentication, authentication failures return consistent responses, and sessions are created only after successful credential verification.

4. Use Secure Password Handling

- ✓ Store passwords using a strong password-hashing mechanism such as Argon2id, bcrypt, or PBKDF2.
- ✓ Passwords should not be stored in plaintext or using reversible encryption.

5. Review Database Permissions

- ✓ Apply the principle of least privilege to the application's database account and remove unnecessary administrative permissions.

6. Conduct Security Retesting

- ✓ After remediation, perform a controlled retest to confirm that admin'-- is treated as ordinary input and does not result in authentication bypass.

9. Conclusion

The assessment identified an authentication-bypass condition consistent with SQL injection through the username parameter. Immediate remediation should focus on parameterized database queries and verification of the authentication workflow. Following remediation, a security retest should be performed to confirm that the vulnerability has been fully resolved.

-End-

 **Author: Bikila Giragn**

Cybersecurity Professional B083

LinkedIn: <https://www.linkedin.com/in/bikila-giragn-827499241/>

 **Project Information**

Program Name: Cybersecurity program at Networkwalks | **Week:** 04 | **Repository:** GitHub